

Level 2.4 - Detect SYN flood

Attackers can use a DNS flood to cause a denial of service on a server.

Password

zavta2cb41

Strategy

The TCP handshake is: SYN (Client -> Server) SYN+ACK (Server -> Client) ACK (Client -> Server)

In a SYN flood, we will see the SYN+ACK but no subsequent ACK. In order to detect a SYN flood, **we will keep track of unanswered SYN+ACKs** (using a **Threshold** object), and if it passes a threshold we deduce we are witnessing a SYN flood attack.

Instructions

1. Create a new module **handshakes.py** with a class **HandshakeTracker** with 2 public methods:
2. **track_synack(self, packet, on_unanswered_synack)**
 - Will be called by main to "feed" a TCP SYN+ACK packet
 - **packet**: The SYN+ACK packet
 - **on_unanswered_synack**: A callback to call if the SYN+ACK isn't answered in 3 seconds
3. **track_ack(self, packet)**
 - Will be called by main to "feed" a TCP ACK packet
 - **packet**: The ACK packet
4. In the main module, create a **HandshakeTracker** object and pass it every SYN+ACK and SYN.
 - Also create a **Threshold** object for keeping track of unanswered SYN+ACKs

5. The `on_unanswered_synack` callback the `HandshakeTracker` is constructed with should use feed `Threshold` object to track a burst of unanswered SYN+ACKs; group them by (SrcIP, DstIP, SrcPort) - remember, the type of packet's we're tracking are unanswered SYN+ACKs - these come from the server, so we need the SrcPort - that is the port targeted by the attacker.
6. In your alert output, include the attacker's IP, the server's IP, and the server's port that was targeted

Notes

Use the guiding questions below to identify the malicious trigger and structure your code's detection:

- What is targetted during a SYN flood?
 - Does it have any fixed characteristics?
 - Can we use this as a unique identifier?
- When does a SYN/ACK no longer need to be tracked?
 - How can we remove it from being tracked after?
- What specific packets do we need to handle?

To submit

Submit a ZIP `nids.zip` containing all `.py` files.

